CVEs más relevantes de la semana

Del 29/09/2026 al 06/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-86131

Descripción: A code injection vulnerability in WatchGuard Fireware OS's BOVPN Over TLS client configuration handling allows an attacker who controls the remote VPN server to execute arbitrary commands as root on the connecting Firebox.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-103109

Descripción: Pexip Infinity before 38.2, plus 39.0, 39.1 and 40.0, is affected by improper input validation in the media implementation that allows a remote attacker to trigger memory corruption or a software abort resulting in a denial of service. A crafted media stream may result in a controlled abort during processing, and has the potential to achieve memory corruption.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-76570

Descripción: Joomla Extension - joomcode.com - Unauthenticated SQL injection in read and write queries in JCTables 1.21.1 - The front-end CRUD API controller performs no Joomla token validation and no authentication check on any task. Table names, column names, and values are taken directly from request parameters and concatenated into SQL queries, allowing SQLi for reading and writing queries.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-100255

Descripción: In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 administrator account takeover was possible via password reset

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1289

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-100273

Descripción: In JetBrains YouTrack before 2026.2.19197 authorisation bypass in the scripts debugger allowed arbitrary code execution

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-100277

Descripción: In JetBrains YouTrack before 2026.2.19197 account takeover was possible by replaying a notification signature

CVSS: 8.9 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-102427

Descripción: Joomla Extension - ordasoft.com - Unauthenticated Remote Code Execution in OrdaSoft Joomla CCK < 8.3.16 - site/uploader.php is reached through the component's normal frontend routing (task=getContent), a task with no authentication or ACL check anywhere in the dispatch chain. The handler validates the uploaded file's content with a real magic-byte MIME check, but the extension allow-list that w...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-102489

Descripción: Zammad versions 6.3.0 to 6.5.4 are vulnerable a session hijack vulnerability that leads to remote code execution as the zammad user. The vulnerability is also present in version 7.0.0 to version 7.1.3, but not exploitable due to environment conditions.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-384

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-102490

Descripción: All versions of Zammad including the latest alpha enable the local zammad user to escalate privileges to root.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-09-30

CVE-2026-86345

Descripción: A flaw was found in 389-ds-base. The server does not discard plaintext bytes already buffered from a client connection when negotiating StartTLS, allowing an on-path attacker to inject a crafted LDAP message that is processed after the TLS upgrade and whose response is delivered to the client in place of the client's own pending operation's response, due to messageID collision. This can cause a...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-923

Tecnología: No especificado

Publicado el: 2026-10-02

CVE-2026-105135

Descripción: A vulnerability has been found in InternLM MindSearch 0.1.0. This issue affects the function ExecutionAction.run of the file mindsearch/agent/graph.py of the component Planner Agent. The manipulation of the argument inputs leads to code injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclos...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-10-04

CVE-2026-105207

Descripción: ZITADEL 3.0.0 through 3.4.15 and 4.0.0 before 4.17.3 creates links between user accounts and external identity providers without verifying a primary factor or the caller's permission, including on identify-only Login V2 sessions and via the User Service V2 AddIDPLink endpoint. An unauthenticated attacker knowing a victim's login name can bind their own external IdP identity to the victim's acco...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-04

CVE-2026-104070

Descripción: The Crayons plugin for SPIP before 3.5.0 contains a missing authorization vulnerability that allows unauthenticated attackers to modify arbitrary editable object fields by omitting the secu_ anti-forgery parameter in crayons_store.php, causing the authorization dispatcher to resolve an unconditionally-true handler instead of the proper modification check. Attackers can chain this flaw to write ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-06

Resumen del Reporte

CVEs analizados: 13

Promedio CVSS: 9.23

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

